

HACKER WOMEN COUNCIL — CERTIFIED ETHICAL HACKING PRACTICAL COURSE

Actividad 01 · Análisis y Planificación del Pentest

Caso de Evaluación de Seguridad Ofensiva: Aurora Market

Organización Objetivo: Aurora Market (E-commerce)	Tipo de Evaluación: Gray-Box Web Penetration Test
Metodología Base: OWASP WSTG v4.2 + PTES	Entorno / Alcance: Aplicación Web, Autenticación y Perfiles

Acceso al desafío del análisis : https://hackerwomen.org/tablero-actividades/#flipbook-df_1489/3/

[1] OBJETIVOS DEL PENTEST

Definición de 3 objetivos concretos para la evaluación de seguridad de Aurora Market:

- **Objetivo 1 — Identificación y Evaluación de Superficie Expuesta:** Identificar, enumerar y evaluar de forma técnica las debilidades y vulnerabilidades de seguridad presentes en la aplicación web de Aurora Market, focalizando el análisis en formularios, mecanismos de autenticación, control de sesiones y gestión de autorizaciones.
- **Objetivo 2 — Determinación de Impacto y Riesgo de Negocio:** Determinar el nivel de riesgo y las posibles consecuencias reales que un actor malicioso externo podría materializar sobre el negocio de Aurora Market (afectación a la confidencialidad de datos de clientes, integridad de transacciones/catálogo y continuidad operativa).
- **Objetivo 3 — Plan de Remediación y Reducción de Riesgos:** Entregar recomendaciones técnicas accionables, mitigaciones preventivas y un plan de remediación priorizado que permita al equipo directivo y técnico de Aurora Market corregir las brechas antes de que puedan ser explotadas.

[2] ALCANCE (SCOPE)

SÍ SE EVALUARÁ (Dentro del alcance)	FUERA DEL ALCANCE (Estrictamente excluido)
● Aplicación web principal autorizada de Aurora Market. ● Endpoints, rutas HTTP/HTTPS, parámetros y cabeceras expuestas. ● Formularios web (login, registro, recuperación, carrito, perfil). ● Mecanismos de autenticación y gestión de sesiones de usuarios. ● Verificación de controles de acceso (roles de usuario vs permisos).	● Redes sociales corporativas o asociadas a la empresa. ● Cuentas de correo electrónico y servidores de mail corporativos. ● Dispositivos personales o estaciones de trabajo de empleados. ● Infraestructura y servicios de proveedores externos / terceros. ● Ataques de Denegación de Servicio (DoS/DDoS) o saturación. ● Afectación, borrado o modificación destructiva de datos reales.

[3] AUTORIZACIÓN Y CONDICIONES

PERMISOS REQUERIDOS	CONDICIONES ACORDADAS
• Carta formal de autorización de pruebas (Rules of Engagement / RoE) firmada por el representante legal o CISO de Aurora Market. • Aprobación explícita sobre las direcciones IP de origen del equipo auditor. • Canal de comunicación de emergencia directo con el contacto técnico asignado. • Cuentas de prueba no privilegiadas para auditoría de perfiles.	• Pruebas ejecutadas estrictamente en ventanas horarias de baja concurrencia. • Enfoque de validación controlada y no destructiva (Proof of Concept seguro). • Suspensión inmediata de pruebas y notificación en caso de riesgo de caída crítica. • Acuerdo estricto de confidencialidad (NDA) sobre hallazgos y evidencias.

[4] TIPO DE PENTEST Y JUSTIFICACIÓN

DECISIÓN TÉCNICA: TIPO DE PENTEST ELEGIDO: GRAY-BOX (Caja Gris)

JUSTIFICACIÓN:

El escenario proporcionado por Aurora Market entrega información inicial de nivel medio/parcial: sabemos que existe una aplicación web, un backend con base de datos, mecanismos de autenticación y distintos perfiles de usuario. Sin embargo, **no se cuenta con acceso al código fuente completo, ni a credenciales de máxima administración, ni a diagramas detallados de red.**

Esta modalidad simula de forma fidedigna y eficiente a un atacante con conocimientos preliminares o a un usuario malicioso que busca escalar privilegios, permitiendo maximizar la cobertura del análisis web sin el sesgo total de White-box ni la ceguera de Black-box puro.

[5] PLANIFICACIÓN DEL PENTEST

Objetivos:	Descubrir debilidades técnicas en autenticación, autorización y lógica de negocio, evaluando su impacto real y facilitando mitigaciones concretas para Aurora Market.
Alcance:	Aplicación web autorizada y sus componentes asociados. Excluye denegación de servicio, ingeniería social, correos y proveedores externos.

Permisos y condiciones:	Autorización formal firmada, franja horaria controlada de bajo tráfico, prohibición de daños colaterales y contacto de guardia operativo.
Metodología a utilizar:	Marco integrado de OWASP WSTG v4.2 (Web Security Testing Guide) guiado por los lineamientos del PTES (Penetration Testing Execution Standard).
Recopilación de información previa:	Identificación de tecnologías web (Wappalyzer / curl), fingerprinting de servidor web, inspección de cabeceras de seguridad y mapeo de rutas públicas expuestas.
Recursos necesarios:	Estación Kali Linux, Burp Suite Community/Professional, Nmap, herramientas de fuzzing web (ffuf/gobuster), SecLists, navegador con Developer Tools.
Programación del pentest:	Ventana de ejecución estructurada en 5 etapas secuenciales durante franjas horarias de bajo impacto, finalizando con la consolidación y entrega del informe.

[6] FASES DEL PENTEST (APLICACIÓN PRÁCTICA A AURORA MARKET)

1. **Reconocimiento:** Recopilación pasiva y semi-pasiva de información pública expuesta por Aurora Market. Identificación de tecnologías web, servidor (Apache/Nginx), frameworks, certificados SSL/TLS y rutas públicas sin enviar tráfico anómalo.
2. **Análisis de Vulnerabilidades:** Inspección activa y análisis de la superficie de ataque: revisión de cabeceras HTTP inseguras, detección de endpoints ocultos, escaneo de formularios, parámetros susceptibles a SQLi/XSS y debilidades en la autenticación/sesiones.
3. **Explotación:** Validación controlada y ética de los fallos encontrados. Se generan pruebas de concepto (PoC) seguras que demuestran la vulnerabilidad (ej. ejecución de script XSS inofensivo o evasión de login) sin comprometer datos reales ni afectar el servicio.
4. **Post-Explotación:** Evaluación del impacto y alcance real del acceso obtenido: determinación de privilegios alcanzados, revisión de si es posible acceder a datos de otros usuarios (IDOR/Broken Access Control) respetando el límite acordado de no alteración.
5. **Informe:** Consolidación de resultados en un reporte profesional que incluye: resumen ejecutivo para directivos, detalle técnico con pasos reproducibles y evidencias fotográficas, cálculo de severidad CVSS y plan de remediación técnico priorizado.

[7] INVESTIGACIÓN DE METODOLOGÍA DE SEGURIDAD

ANÁLISIS METODOLÓGICO: METODOLOGÍA ELEGIDA:
OWASP Web Security Testing Guide (WSTG v4.2)

¿POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO?:

1. Estándar de la Industria: Es la guía técnica de referencia global más completa para evaluar la seguridad en aplicaciones web, cubriendo exactamente las áreas declaradas por Aurora Market (mecanismos de autenticación, gestión de sesiones, validación de datos y roles de usuario).
2. Enfoque Modular y Exhaustivo: Ofrece vectores de prueba específicos (checklists) categorizados (WSTG-ATHN, WSTG-SESS, WSTG-INPV, WSTG-ATHZ) que permiten auditar paso a paso vulnerabilidades críticas como Inyecciones (SQL/NoSQL), Cross-Site Scripting (XSS), Fallos de Control de Acceso (IDOR / BAC) y Mala Configuración de Seguridad.
3. Compatibilidad con Pruebas Seguras: Cada prueba de WSTG está orientada a la verificación empírica sin necesidad de causar daños colaterales a la base de datos o interrumpir la continuidad operativa de la tienda.

Auditor / Estudiante: Nathalie Carrasco

Fecha de Entrega: Septiembre 2026